Preguntas probables para estudiar

Respuestas cortas y honestas. Estudienlas en voz alta: si no pueden explicar algo con sus palabras, vuelvan al PDF simple o a la guia tecnica. Cuando no sepan algo, es mejor decir "eso no lo probamos" que inventar.

Consejos para la defensa

- Lleven siempre la respuesta al flujo: *que hace la persona, que hace la API, que guarda la base*.
- Las limitaciones se dicen ustedes primero (bucket publico, carga en PC local, sin pasarela de pago).
- Cada uno debe poder explicar el diagrama de arquitectura y el sistema de puntos sin mirar.
- Tengan abierta la demostracion en produccion y una cuenta de familia, una de cuidadora y la de administrador ya iniciadas.

Proyecto y alcance

1. Que problema resuelve AgeCare?

Las familias que necesitan una cuidadora para un adulto mayor no tienen donde encontrar personas verificadas, y Wellq no tiene como revisar documentos, premiar a las buenas cuidadoras ni moderar resenas. Hicimos el marketplace de cuidadoras (con resenas, puntos y ranking) dentro de su Consola, y un sitio publico para probarlo de punta a punta.

2. Que era lo que pedia el cliente y que hicieron de mas?

El modulo de marketplace de cuidadoras con fidelizacion integrado a la Consola. De mas: el sitio publico completo (registro, busqueda, chat, contratacion, resenas), eliminacion de datos, moderacion de resenas, pruebas de seguridad y de carga.

3. Como se reparten el trabajo?

Revisar el archivo Fase 2/Aporte del equipo.md: sale del historial de Git. Julio trabajo sobre todo en el sitio y la monetizacion (cobro de verificacion y articulos patrocinados); Bryan en despliegue, Consola, fidelizacion, pruebas y seguridad. Ambos pueden explicar cualquier parte del flujo.

4. Que es lo mas dificil que resolvieron?

Mantener dos sistemas coherentes: lo que el staff decide en la Consola tiene que verse en el sitio. Si el aviso falla, la accion se cancela; no se acepta que queden distintos.

Herramientas y arquitectura

5. Por que FastAPI y no otra cosa?

Es rapido, asincrono, valida datos con Pydantic y genera documentacion Swagger sola. El cliente entrego una especificacion de endpoints y Swagger nos permite mostrar que la cumplimos.

6. Por que Vercel y Supabase?

Son gratuitos para un proyecto academico, se conectan a GitHub (cada subida despliega sola) y Supabase da PostgreSQL de verdad con almacenamiento de archivos. Limitacion: el plan Hobby no es para uso comercial.

7. Usan Docker en produccion?

No. Docker lo usamos en nuestros computadores para levantar PostgreSQL y probar. En produccion todo corre en Vercel (funciones) y Supabase.

8. Por que dos APIs y no una?

Porque el cliente tiene una Consola interna aparte de la app de usuarios. Separar permite que cada una tenga sus roles y su ciclo de cambios, y se comunican con una clave interna.

9. Como se comunican las dos APIs?

Por HTTPS con la cabecera X-Internal-Key. El sitio avisa a la Consola (perfil, documentos, resenas) y la Consola avisa al sitio (aprobacion, revision de documentos, moderacion).

10. Que pasa si una de las APIs esta caida?

Si el sitio no puede avisar a la Consola, lo que hizo la persona igual se guarda (mejor esfuerzo) y la Consola lo recupera al consultar. Si la Consola no puede avisar al sitio, la accion del staff se cancela con un mensaje para repetirla.

11. Que es una migracion y por que dos mecanismos?

Es un script versionado que cambia la estructura de la base. La Consola usa Alembic; ademas, al primer uso de cada instancia se agregan columnas faltantes de forma idempotente, para no depender de pasos manuales en Supabase.

12. Que es JWT?

Un pase firmado con vencimiento corto que la API entrega al iniciar sesion. Con el refresh token se renueva; si alguien reutiliza uno ya usado, se revocan todas las sesiones.

13. Para que sirve Pydantic?

Valida cada dato que llega (formato de correo, largos maximos, tipos). Los datos malos se rechazan con 422 antes de tocar la base.

Seguridad

14. Como evitan que entren con inyeccion SQL?

Nunca armamos consultas con texto: SQLAlchemy usa parametros. Ademas Pydantic valida el formato. Lo probamos con 8 cargas tipicas (por ejemplo ' OR '1'='1) en login, filtros, textos e identificadores: nunca entra y la base queda intacta.

15. Como guardan las contrasenas?

Con Argon2id, un cifrado que no se puede revertir y es deliberadamente lento. Usamos los parametros minimos de OWASP (19 MiB, 2 pasadas, 1 hilo).

16. Bajar el costo de Argon2 no es menos seguro?

Si, es un equilibrio: cada hash cuesta la mitad, y es lo que OWASP lista como configuracion minima valida. Lo hicimos porque el servidor aguantaba 14 inicios de sesion por segundo y ahora ~60. Las contrasenas antiguas siguen funcionando porque cada hash lleva sus parametros.

17. Que encontraron con las pruebas de seguridad?

Una falla real: en el sitio publico el bloqueo tras 5 contrasenas incorrectas no funcionaba, porque el contador se guardaba y luego se revertia al responder el error. Se podia probar contrasenas sin limite. Se corrigio y quedo una prueba.

18. Que pasa si alguien falsifica un token?

Se rechaza: probamos token sin firma, firmado con otra clave, vencido, de usuario inexistente y con otro algoritmo. El rol sale de la base de datos, no del token, asi que un analista no puede ascender editandolo.

19. Una familia puede ver los datos de otra?

No: cada ruta verifica pertenencia (403/404). Hay pruebas de acceso a familiares y chats ajenos.

20. Como protegen los documentos de las cuidadoras?

Se valida que el archivo sea realmente lo que dice (por su firma), maximo 4 MB, y el nombre es imposible de adivinar. Limitacion declarada: el bucket es publico; para datos reales debe pasar a privado con URLs firmadas.

21. Y si en Vercel quedara una clave de ejemplo?

Seria grave porque permitiria falsificar sesiones. Agregamos un aviso critico en el log al arrancar si detecta valores de ejemplo, y esta en la lista de verificacion de despliegue.

22. Que es XSS y que hacen?

Insertar scripts en un texto para que se ejecuten en el navegador de otro. La API los guarda como texto, los devuelve como JSON con nosniff, y React escapa el contenido al mostrarlo.

Fidelizacion y resenas (nuestro modulo)

23. Como funciona el sistema de puntos?

Trabajo cerrado con resena +10. Si la resena es de 4 o 5 estrellas, +5 de bono. 3 estrellas, neutra. 2 estrellas resta 5 y 1 estrella resta 15. El total es la suma del historial y ordena el ranking.

24. Por que las malas resenas restan?

Para que el ranking premie la calidad y no solo la cantidad de trabajos. Una cuidadora con varias resenas de 1 estrella queda en negativo y baja en el ranking.

25. Que diferencia hay entre archivar y eliminar una resena?

Archivar la oculta y la saca de la nota y de los puntos, pero se puede restaurar. Eliminar la borra definitivamente junto con sus puntos. Ambas piden confirmacion, quedan en auditoria y el sitio publico se actualiza.

26. Por que el total de puntos no es una columna?

Para que no se desincronice: siempre se calcula desde el historial, que ademas explica de donde salio cada punto.

27. Que pasa si el sitio no responde al archivar una resena?

No se cambia nada y se avisa al staff para reintentar; asi los dos sistemas no quedan distintos.

Rendimiento y usuarios simultaneos

28. Aguanta cientos de usuarios a la vez?

En un PC de escritorio con todo corriendo en la misma maquina: 100 y 300 usuarios simultaneos sin errores (con esperas a 300), y 500 lo satura. En Vercel cada peticion corre en su propia funcion y escala sola; el limite pasa a ser las conexiones de Supabase.

29. Probaron en produccion?

No una prueba de carga, porque crearia miles de cuentas en datos reales. Si medimos latencia en produccion con peticiones de lectura: bajo de ~1,3 s a ~0,3 s.

30. Que fue lo que mas mejoro la velocidad?

Poner las funciones de Vercel en Sao Paulo, junto a la base. Estaban en Washington y cada peticion pagaba el viaje varias veces.

31. Por que las respuestas bajo carga eran lentas?

Porque las peticiones hacen fila: una maquina procesa unas 50 por segundo. Es capacidad, no un error: a 300 usuarios todas terminan bien.

32. Que errores encontraron con la carga?

Cuatro reales: el hash de contrasenas bloqueaba al servidor, la API respondia antes de guardar (403/404 al azar), se agotaba el pool de conexiones y se hacian consultas de limpieza de mas en cada visita al chat.

33. Por que el generador de carga es en Node y no Python?

El cliente HTTP de Python gastaba mas CPU que el propio servidor y falseaba las mediciones; medimos primero al medidor.

Pruebas y calidad

34. Cuantas pruebas tienen?

177 automaticas (83 Consola y 94 sitio), 78 de ellas de seguridad, mas un recorrido E2E con navegador de 34 pasos, y 4 trabajos de CI en cada subida.

35. Para que sirve el CI?

Cada vez que subimos codigo, GitHub Actions corre las pruebas y compila las webs; si algo falla, no pasa desapercibido.

36. Por que el E2E dio resultados distintos?

Con el PC cargado (juego, Docker, Chrome) vario entre 12 y 32 de 34 sin cambiar codigo: eran esperas fijas de la propia prueba. Las cambiamos por esperas a la condicion real. Debe repetirse con el equipo libre antes de presentar.

37. Que bugs encontraron con las pruebas?

El bloqueo de cuenta que no persistia, el guardado posterior a la respuesta, y un boton de la Consola que se habilitaba antes de recargar y daba un error 409 al hacer doble clic.

Negocio y futuro

38. Como se financia o rentabiliza?

Cobro unico de verificacion a cuidadoras nuevas (9.990 CLP, con estados pendiente, pagado o eximido y referencia de pago) y articulos de apoyo patrocinados, con comision y registro de clics. Hoy el pago se confirma manualmente; falta integrar una pasarela.

39. Que le falta antes de lanzarse de verdad?

Bucket privado para documentos, recuperacion de contrasena, textos legales, plan Pro de Vercel y respaldos. Esta en la lista de verificacion de DESPLIEGUE.md.

40. Se puede integrar con otros modulos del cliente?

Si: estamos coordinando con el equipo del repositorio de administracion comun. Nuestras reglas y endpoints estan documentados en Swagger y en este informe.

41. Que aprendieron?

Que medir antes de optimizar evita arreglar lo que no era el problema; que las pruebas encuentran fallas de seguridad que no se ven a ojo; y que mantener dos sistemas sincronizados exige decidir que pasa cuando una parte falla.

42. Que harian distinto?

Probar la carga y la seguridad desde el principio y no al final, y desplegar desde el dia uno en la misma region que la base.